IIM Handbook — Code Review

Scope: database.rules.json, index.html, scripts/, CI workflow, manifest and service worker. admin.html and profile.html were only spot-checked. Nothing was executed; findings are from reading the code.

Security

#	Severity	Finding	Fix
1	High	**Recording links are public in page source.** Drive recording URLs and Zoom ?pwd= join links sit in the RECORDINGS array (index.html:2456-2624). The calOnly class and canOpenLink only hide them in the UI (your TODO at line 2451 notes this). They also remain in git history.	Move the links to the admin-only Firebase nodes (recordingUrls / recordings already exist), delete them from the file, and rotate Drive sharing if recordings must be members-only.
2	Medium	**Unvalidated event links can run JavaScript.** The evLink input (admin.html:1143) is type=url, which accepts javascript:. calendarEvents rules do not check link, esc() does not strip schemes, and index.html:3519 calls window.open(dataset.url). Needs a hostile or compromised admin.	Add .matches(/^https:\/\//) to the rules, use the existing isHttps (admin.html:1801) in the form, and check on render.
3	Medium	**Open write rules.** presence: anyone can create or delete any entry (inflates/wipes the online count). visitorLog and pwaInstalls: no field whitelist or size limit (spam/cost). totalVisits: anyone can bump it repeatedly. The REST endpoint can be called without your page.	Add .validate rules with $other: false, string length caps, and consider App Check.
4	Medium	**Visitor tracking.** IP, ISP, city, user agent and a persistent device id are stored, and each visitor's IP is sent to the third-party ipwho.is. The disclosure (index.html:1729) is click-through, not consent. IP/location values are client-supplied and spoofable.	Check against DPDP Act / GDPR if applicable; consider dropping IP/ISP or resolving location server-side.
5	Low	A super admin can overwrite another super's role with admin; admin rules accept unknown extra fields; the Firebase apiKey is public (normal) but should be domain-restricted.	Tighten roles rule; restrict the key in Google Cloud.

Bugs and logic

- **Engagement data is cut short.** sendEngagement fires once, on the first visibilitychange to hidden (index.html:2185), and the rules allow each field to be written only once. Tab-switchers get a duration/engagement record frozen at the first hide.
- **Fast bounces are lost.** writeVisitLog runs only after the ipwho.is fetch returns; if the visitor leaves first or an ad blocker stalls it, nothing is logged.
- **Presence scales badly.** db.ref('presence').on('value') sends every entry to every client on every change (bandwidth grows with the square of visitors). Fine for a class; use a counter if it grows.
- **Inconsistent gating.** The Calendar tab uses canOpenLink but the Recordings cards (index.html:2765) do not; they depend only on the CSS class.
- **Missing text.** An announcement with no text renders as the string 'undefined' (index.html:3689).

Tooling and CI

- **Link checks rarely fail.** validate-data.mjs fails only on 404, but Drive and Zoom return 200 or a login page for dead links, so the weekly check proves little. It also does not check that subject exists in SUBJECTS, that time/ends parse, or that URLs are https.

- **add-recording.mjs.** The endsWith(',') branch (line 128) can never run; url and thumb are not validated; on a CRLF checkout it mixes line endings.
- **PWA icon.** manifest.json declares logo.jpg as both 192x192 and 512x512, but it is 354x357 and non-square. Generate square PNGs.
- **Service worker** has an empty fetch handler, so there is no offline support (fine if intended).

Suggested order

1. Move the recording URLs out of index.html into Firebase (item 1).
2. Add https validation for event links and cap the unauthenticated writes in the rules (items 2 and 3).
3. Fix the manifest icons.